

Security+ 1.1 · Security Controls

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · Aula 1.1 — Security Controls (11:48) ·

[Vídeo no YouTube ↗](#)

Resumo da Aula: Controle = qualquer medida que evita, avisa, conserta ou compensa. 4 CATEGORIAS (by means): Technical (ferramenta), Managerial (documento/política), Operational (pessoas no dia-a-dia), Physical (barreira física). 6 TIPOS (by purpose): Preventive (barra antes), Deterrent (desanima), Detective (avisa depois), Corrective (repara), Compensating (plano B), Directive (direciona). A prova dá um CENÁRIO e pede a classificação nas duas dimensões.



Highlights que a prova cobra

- Matriz 4×6 = a tabela mental da aula
- Preventive barra ANTES — Detective AVISA — Corrective CONCERTA
- Compensating: usa MEIOS DIFERENTES quando o ideal não dá — temporário
- Directive = o mais fraco: 'authorized personnel only' não barra ninguém
- Antivírus: technical + preventive e detective dependendo do modo
- Extintor de incêndio = corrective — repara durante, NÃO previne



Dicas de prova & Cenários Típicos

- Gatilhos: 'after the event' → corrective · 'discourage' → deterrent · 'identifies/logs' → detective · 'alternative approach' → compensating
- A pergunta do Messer: 'what CATEGORY does it fit in (technical/managerial/operational/physical) AND what TYPE?'

Cenário clássico de exame: Um cenário típico: 'organização exige dois administradores autorizem pagamento' → compensating/managerial (separation of duties). 'Restaura backup após ransomware' → corrective/technical. 'Placa sem fechadura: authorized personnel only' → directive/physical.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Seção 1.1)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (Security Controls) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Criptografia Simétrica (AES-256, ChaCha20):** Usa uma única chave idêntica para cifrar e decifrar. Excelente para confidencialidade de grandes volumes (BitLocker, banco de dados, túneis VPN). **Atenção de prova:** cifras simétricas NÃO oferecem não-repúdio quando a chave é compartilhada.
- **Criptografia Assimétrica (RSA, ECC, Ed25519):** Usa par de chaves matemáticas: a Chave Pública é distribuída livremente; a Chave Privada é mantida em segredo absoluto pelo titular. Assinar o hash com a chave privada garante **Não-repúdio e Autenticidade**. Cifrar com a chave pública do destinatário garante **Confidencialidade**.
- **Hashing (SHA-256, SHA-3) vs. HMAC:** Hash puro é função matemática unidirecional sem chave, garantindo apenas integridade (qualquer um pode recalculá-lo de um dado adulterado). O HMAC combina hash com chave simétrica secreta, provendo integridade e autenticação mútua entre sistemas conhecidos.
- **TSA (Time Stamping Authority - RFC 3161) e LTV:** Entidade confiável que assina o hash com data/hora auditada, provando o momento exato em que o documento existiu e garantindo validação de longo prazo (LTV) mesmo após a expiração de certificados.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Hash puro NÃO fornece não-repúdio.
- AES com chave compartilhada destrói o não-repúdio.
- Políticas em papel e termos de adesão são controles puramente administrativos; não bloqueiam ataques em tempo de execução.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. Um administrador instala uma regra de firewall que bloqueia todo tráfego de entrada vindo de uma faixa de IP conhecida por ser maliciosa. Qual combinação classifica corretamente este controle?

- A)** Preventive · Technical
- B)** Detective · Technical
- C)** Preventive · Managerial
- D)** Deterrent · Technical

2. A empresa instala placas na entrada dizendo 'esta área está sendo gravada por câmeras de segurança'. Nenhum dispositivo físico novo foi adicionado. Qual é o propósito primordial deste controle?

- A)** Preventive
- B)** Detective
- C)** Deterrent
- D)** Compensating

3. Depois de um ataque de ransomware, o time de TI apaga o disco da máquina e restaura os dados do backup de ontem. Este controle é:

- A)** Detective
- B)** Corrective
- C)** Preventive
- D)** Compensating

4. Um software crítico da empresa tem uma vulnerabilidade grave, mas o fornecedor só poderá enviar o patch em 2 meses. A solução temporária de bloquear a porta específica no firewall até o patch chegar é qual tipo de controle?

- A)** Corrective
- B)** Detective
- C)** Compensating
- D)** Preventive

5. A organização implementa a política de que NINGUÉM (nem o administrador do sistema) pode aprovar e executar um pagamento sozinho — sempre precisa de duas pessoas. Isso é:

- A)** Preventive control do tipo managerial (separation of duties)
- B)** Detective control do tipo technical
- C)** Compensating control do tipo operational (dupla guarda)
- D)** Directive control do tipo physical

6. Guardas fazem rondas pelo prédio a cada hora. Quando um guarda descobre portas abertas que não deviam estar, reporta imediatamente. Este controle é:

- A)** Detective · Operational (patrulha)
- B)** Preventive · Physical (patrulha)
- C)** Corrective · Operational
- D)** Detective · Technical

7. A empresa escreve um documento oficial de política de segurança que define como funcionários devem tratar dados sensíveis. Qual o tipo + categoria?

- A)** Directive + Managerial
- B)** Preventive + Managerial
- C)** Directive + Technical
- D)** Corrective + Managerial

8. Depois de um ataque bem-sucedido, o time de segurança monta um relatório do que aconteceu pra evitar repetição — inclusive atualizando o playbook. Qual controle é este?

- A)** Detective
- B)** Corrective — na categoria managerial (processo, documentação)
- C)** Preventive
- D)** Compensating

9. O datacenter instalou detector de movimento que dispara alarme e notifica os guardas quando há movimento fora do horário. Esta combinação:

- A)** Detective + Technical
- B)** Detective + Physical
- C)** Preventive + Physical
- D)** Deterrent + Technical

10. Depois de um incidente, o time de segurança adiciona um módulo de antivírus adicional à borda da rede, porque o sistema legado não pode ter o patch aplicado. Este é um exemplo de:

- A)** Compensating control — uma alternativa porque o controle ideal não é possível
- B)** Corrective control — corrige o que já aconteceu
- C)** Preventive — barra o ataque antes
- D)** Deterrent — desanima o atacante

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) A — Preventive · Technical.

Firewall é ferramenta tecnológica (Technical); a regra barra o pacote antes de entrar na rede (Preventive).

2) C — Deterrent.

O aviso desanima e desencoraja a ação maliciosa (Deterrent), mas não impede fisicamente a entrada nem grava nada por si só.

3) B — Corrective.

A restauração do backup ocorre DEPOIS do incidente para restaurar o estado operacional do sistema (Corrective).

4) C — Compensating.

Compensating control: é uma contramedida alternativa temporária aplicada quando o controle principal/ideal (o patch do fabricante) é inviável no momento.

5) A — Preventive control do tipo managerial (separation of duties).

Separação de funções (separation of duties) é uma política administrativa/gerencial (Managerial) que previne fraudes e erros impedindo a ação unilateral (Preventive).

6) A — Detective · Operational (patrulha).

A patrulha de segurança faz parte dos procedimentos operacionais humanos (Operational) e atua identificando anomalias durante a inspeção (Detective).

7) B — Preventive + Managerial.

Política de segurança orienta e evita o erro (Preventive) via processo administrativo e diretriz organizacional (Managerial).

8) B — Corrective — na categoria managerial (processo, documentação).

Lições aprendidas e atualização de políticas após incidente é um controle corretivo (Corrective) no nível gerencial/processual (Managerial).

9) B — Detective + Physical.

Detetores de movimento e sensores volumétricos são dispositivos físicos (Physical) cuja função é detectar intrusões e emitir alertas (Detective).

10) A — Compensating control — uma alternativa porque o controle ideal não é possível.

Compensating: uso de outros meios para compensar a ausência de um controle primário (sistema operacional legado sem suporte a patches).